Cloud hardening under attack simulation: Entra and M365

An expert project playbook that chains ScubaGear, Monkey365, Maester, Prowler, ROADtools and AADInternals: establish a measurable Entra/M365 baseline, run authorized directory enumeration as adversary emulation, then close the loop with detection validation and remediation. Defensive use only.

9 phases | 21 steps | Tick each item when its "done when" criterion is true

Phase 1 Authorize the engagement and lock the scope about 1–3 days

- [ ] **1.1 Get written authorization and a rules-of-engagement sheet**
  A signed (or ticketed) approval names the tenants, subscriptions, date window, allowed techniques and a stop-contact
- [ ] **1.2 Notify the SOC and freeze false-positive handling**
  SOC / security operations has the engagement window, source IPs or jump hosts, and the test account UPNs
- [ ] **1.3 Prepare accounts, break-glass exclusions and a clean workstation**
  A least-privilege read account (or app) for scanners, a separate privileged read account for MFA/role dumps, break-glass excluded from blocking CA, and a hardened admin workstation

Phase 2 Baseline with CISA ScubaGear about 0.5–1 day

- [ ] **2.1 Install ScubaGear on Windows PowerShell 5.1 and verify the version**
  `Invoke-SCuBA -Version` returns a version; dependencies installed via `Install-ScubaDependencies`
- [ ] **2.2 Run the assessment and capture the HTML/JSON/CSV output**
  A dated report folder exists for Entra (`aad`), security suite, Exchange, SharePoint and Teams (and Power Platform / Power BI only if licensed and in scope)

Phase 3 Widen the lens with Monkey365 and Maester about 1–2 days

- [ ] **3.1 Run Monkey365 against Microsoft 365 with Entra included**
  An HTML (or CSV) Monkey365 report covers Exchange Online, Teams, SharePoint Online and Entra ID for the engagement tenant
- [ ] **3.2 Install Maester and run the Pester-based Entra/M365 tests**
  `Invoke-Maester` produces an HTML report; failed Conditional Access and privileged-role tests are listed in the backlog

Phase 4 Add Prowler for Azure and Microsoft 365 provider checks about 0.5–1 day

- [ ] **4.1 Authenticate Prowler with a least-privilege app or browser session**
  Prowler can list the in-scope Azure subscriptions and/or the M365 tenant without using a standing Global Administrator password
- [ ] **4.2 Run identity, storage and logging checks first; archive JSON/HTML**
  A dated Prowler output set exists; high findings for identity, storage and logging are in the backlog with check IDs

Phase 5 Build one risk backlog from four scanners about 1–2 days

- [ ] **5.1 Deduplicate and classify findings across ScubaGear, Monkey365, Maester and Prowler**
  One backlog (work item tracker or spreadsheet) with columns for source tool, control/check ID, asset, severity, owner, due date and status
- [ ] **5.2 Pick the remediations that shrink attacker value before enumeration**
  Break-glass, blocking legacy auth (or a dated plan), MFA/authentication strength and consent restrictions are either fixed or explicitly deferred with a ticket

Phase 6 Adversary-style directory enumeration with ROADtools about 0.5–1 day

- [ ] **6.1 Install ROADrecon and authenticate with device code**
  `.roadtools_auth` exists from a successful `roadrecon auth` ; Python 3.10+ on the jump host
- [ ] **6.2 Gather the tenant snapshot and review high-value objects in the GUI**
  `roadrecon.db` gathered; GUI review notes cover privileged roles, stale guests, over-permissioned apps and interesting OAuth grants

Phase 7 Deep Entra checks with AADInternals about 0.5–1 day

- [ ] **7.1 Install AADInternals and obtain a cached token**
  Modules imported; `Get-AADIntAccessTokenForAADGraph -SaveToCache` (or MS Graph equivalent) succeeded for the assessment identity
- [ ] **7.2 Run the read-only checklist agreed in the engagement plan**
  Notes exist for federation/PTA/seamless SSO posture, service locations, and any sync or application-credential oddities in scope — without unplanned writes

Phase 8 Prove detection: logs, risk and Conditional Access about 1–2 days

- [ ] **8.1 Review sign-in and audit logs for the engagement activity**
  Sign-in logs show the assessment authentications and CA results; audit logs show any directory reads/changes in scope; gaps are ticketed
- [ ] **8.2 Align ID Protection risk signals with Conditional Access (report-only first)**
  User-risk and sign-in-risk policies exist as separate Conditional Access policies in Report-only (or a dated migration plan from legacy ID Protection policies)

Phase 9 Remediate, re-baseline and close the engagement about 3–10 days

- [ ] **9.1 Drive the backlog through change control with rollback notes**
  Every 'fix now' item is closed or accepted; every CA/Entra change has a rollback path (Report-only/Off, previous role assignment, previous consent setting)
- [ ] **9.2 Re-run the baseline tools and publish the delta**
  A second dated archive of ScubaGear (+ at least Maester or Monkey365) exists; the backlog shows which check IDs moved from fail to pass
- [ ] **9.3 Revoke access, wipe exports and schedule the recurring loop**
  Assessment secrets rotated/disabled; `roadrecon.db` / token files wiped or vaulted; Maester or ScubaGear scheduled for recurring drift detection
- [ ] **9.4 Troubleshoot a workload policy that appears to do nothing**
  The evidence names the service-principal object, supported identity type, policy mode and sign-in policy result; unsupported paths have separate controls

Owner	Change / ticket	Date completed

Original checklist by Tenant Recipes, an independent project not affiliated with Microsoft or any vendor. Every step, its actions, pitfalls and the official sources it was checked against are on https://tenantrecipes.com/guides/cloud-hardening-adversary-emulation.html. Time estimates are our own planning figures. Confirm against the linked sources and test in a pilot before production.